

Mapeo de preguntas de la encuesta a requisitos normativos y marcos de referencia

La siguiente tabla muestra, para cada pregunta de la encuesta (número y tema), los artículos o controles específicos de los principales marcos y regulaciones que la respaldan.

Se utilizan las versiones vigentes a abril 2026: NIS2 Directiva (UE) 2022/2555, NIST CSF 2.0, ISO/IEC 27001:2022, Esquema Nacional de Seguridad (ENS) real-decreto 311/2022, y el framework MITRE ATT&CK® (v13).

Nº Pregunta	Tema principal	NIS2 (artículo)	NIST CSF 2.0 (función/categoría)	ISO 27001:2022 (Anexo A)	ENS / CCN-STIC	MITRE ATT&CK / Otros
1-5	Perfil de la organización	— (contexto)	ID.GV-01 (Governance)	4.1, 4.2 Contexto de la organización	ENS: Categoría de entidad y aplicabilidad	N/A
6	Estrategia formal de ciberseguridad con enfoque APT	Art. 21, 23 (gestión de riesgos)	ID.GV-01, ID.GV-02	A.5.1 Políticas de seguridad de la información	ENS: Política de seguridad	N/A
7	Alineamiento con marcos de referencia	Art. 21 (medidas técnicas y organizativas)	ID.GV-03	A.5.1, A.5.2	ENS: Implantación de medidas	N/A
8	Estado de cumplimiento NIS2	NIS2 completa (art. 21-23)	ID.GV-01-03	Cláusulas 4-10 generales	ENS: Marco global	N/A
9	Revisión de estrategia y políticas	Art. 21.2 (revisión periódica)	ID.GV-02	A.5.1, A.5.3	ENS: Revisión periódica	N/A
10	Participación del Consejo / Alta Dirección	Art. 20 (responsabilidades de la dirección)	ID.GV-01	A.5.1, A.5.2	ENS: Responsabilidad y funciones	N/A
11-12	Mapa de riesgos y actualización	Art. 21 (gestión de riesgos)	ID.RA-01-03	A.5.4 Gestión del riesgo	ENS: Análisis y gestión de riesgos	N/A
13	Métricas MTTD, MTTR, MTTP, % phishing, TTPs MITRE, incidentes en cadena de suministro	Art. 21 (monitorización)	ID.IM-01-04, DE (Detection), RS (Response)	A.5.35 Monitorización y revisión	ENS: Explotación de medidas	ATT&CK: Técnicas específicas (ver 22.x)

14	Cuantificación económica del riesgo	Art. 21 (riesgos y medidas)	ID.RA-02	A.5.4	ENS: Gestión de riesgos	N/A
15	Integración en continuidad de negocio	Art. 21 (planificación)	ID.BE-05, RS.RP	A.5.30 Planificación de continuidad	ENS: Continuidad del servicio	N/A
16-17	Phishing y spear-phishing	Art. 21 (medidas técnicas)	PR.AT-01, PR.PT-01	A.5.10 Concienciación, A.5.15 Controles de acceso	ENS: Protección de la información	ATT&CK: Initial Access (phishing)
18	Gestión del parcheo (MTTP)	Art. 21 (gestión de vulnerabilidades)	ID.VM-01-03, PR.PT-03	A.8.8 Gestión de vulnerabilidades técnicas	ENS: Explotación y mantenimiento	ATT&CK: Vulnerability exploitation
19	Fuentes de Threat Intelligence	Art. 21 y 26 (cooperación)	ID.IM-03	A.5.7 Contacto con autoridades	ENS: Relación con CSIRT nacionales	ATT&CK: Threat Intel mapping
20	Cadena de suministro digital	Art. 21.2(e) (seguridad de la cadena de suministro)	ID.SC-01-04	A.5.19 Seguridad en relaciones con proveedores	ENS: Proveedores de servicios	N/A
21-22	Uso de MITRE ATT&CK y TTPs	Art. 21 (detección avanzada)	DE.AE-01-03	A.5.35 Monitorización	ENS: Detección de intrusiones	MITRE ATT&CK (técnicas específicas)
23-24	Plan de detección APT e IA/ML	Art. 21	DE.AE-01-05, DE.DP	A.5.35, A.8.16	ENS: Sistemas de monitorización	ATT&CK, modelos analíticos
25-27	Plan de respuesta a incidentes y métricas	Art. 23 (gestión de incidentes)	RS.RP-01-03	A.5.26 Gestión de incidentes	ENS: Respuesta a incidentes	N/A
28	Coordinación con INCIBE / CCN-CERT	Art. 23-26 (notificación y cooperación)	RS.CO-01-03	A.5.7	ENS: CSIRT de referencia	N/A

29-32	Formación, canales de reporte y cultura	Art. 20, 21	PR.AT-01-04	A.6.3 Responsabilidades, A.6.4 Concienciación	ENS: Formación y concienciación	N/A
33-36	Inversión, ROI e IGM	Art. 21 (suficiencia de recursos)	ID.GV-02, ID.RA-03	A.5.1, A.5.4	ENS: Gestión de recursos	N/A
37-39	Colaboración y ejercicios conjuntos	Art. 26 (cooperación)	ID.IM-03, RS.CO-02	A.5.7 Contacto con autoridades	ENS: Colaboración	ATT&CK: Adversary emulation
40-41	Visión de futuro y prioridades	Orientación estratégica	ID.GV-01-03	A.5.1, A.5.2	ENS: Planificación	N/A
42	Comentario abierto	N/A	N/A	N/A	N/A	N/A

Nota: Cada fila puede ampliarse con los sub-controles específicos (por ejemplo, A.8.8.1 para gestión de parches) al realizar un análisis de brechas profundo. Este mapeo sirve como base para demostrar cumplimiento en auditorías o auto-evaluaciones.